

Отчет по первому этапу индивидуального проекта

Основы информационной безопасности

Дауд Амжад

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	16
	Список литературы	17

Список иллюстраций

4.1	Клонирование репозитория	9
4.2	Изменение прав доступа	9
4.3	Перемещение по директориям	10
4.4	Создание копии файла	10
4.5	Открытие файла в редакторе	10
4.6	Редактирование файл	11
4.7	Запуск mysql	11
4.8	Авторизация в базе данных	12
4.9	Изменение прав	12
4.10	Перемещение между директориями	12
4.11	Открытие файла в текстовом редакторе	12
4.12	Редактирование файла	13
4.13	Запуск arche	13
4.14	Запуск веб-приложения	14
4.15	«Создание базы данных»	14
4.16	Авторизация	15
4.17	Домашняя страница DVWA	15

Список таблиц

1 Цель работы

Приобретение практических навыков по установке DVWA.

2 Задание

1. Установить DVWA на дистрибутив Kali Linux.

3 Теоретическое введение

DVWA - это уязвимое веб-приложение, разработанное на PHP и MYSQL.

Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. - Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. - Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение. - SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: - Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. - Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях. - Средний — этот уровень безопасности

предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. - Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб-приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации. **[guide]**

4 Выполнение лабораторной работы

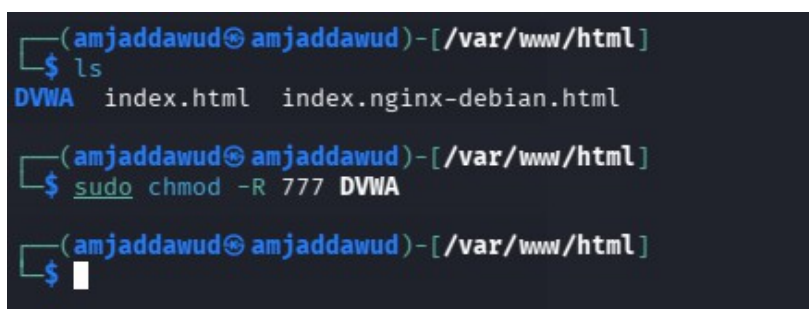
Настройка DVWA происходит на нашем локальном хосте, поэтому нужно перейти в директорию `/var/www/html`. Затем клонирую нужный репозиторий GitHub (рис. 1).



```
(amjaddawud@amjaddawud)~  
$ cd /var/www/html  
  
(amjaddawud@amjaddawud)-[/var/www/html]  
$ sudo git clone https://github.com/ethicalhack3r/DVWA  
[sudo] password for amjaddawud:  
Cloning into 'DVWA' ...  
remote: Enumerating objects: 5663, done.  
remote: Counting objects: 100% (18/18), done.  
remote: Compressing objects: 100% (9/9), done.  
remote: Total 5663 (delta 12), reused 9 (delta 9), pack-reused 5645 (from 4)  
Receiving objects: 100% (5663/5663), 2.71 MiB | 50.00 KiB/s, done.  
Resolving deltas: 100% (2826/2826), done.  
  
(amjaddawud@amjaddawud)-[/var/www/html]  
$
```

Рисунок 4.1: Клонирование репозитория

Проверяю, что файлы скопировались правильно, далее повышаю права доступа к этой папке до 777 (рис. 2.)



```
(amjaddawud@amjaddawud)-[/var/www/html]  
$ ls  
DVWA index.html index.nginx-debian.html  
  
(amjaddawud@amjaddawud)-[/var/www/html]  
$ sudo chmod -R 777 DVWA  
  
(amjaddawud@amjaddawud)-[/var/www/html]  
$
```

Рисунок 4.2: Изменение прав доступа

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверяю содержимое каталога (рис. 3)

```
(amjaddawud@amjaddawud)-[/var/www/html]
$ cd DVWA/config

(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist
ls: that file contains the default
(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$
```

Рисунок 4.3: Перемещение по директориям

Создаем копию файла, используемого для настройки DVWA `config.inc.php.dist` с именем `config.inc.php`. Копируем файл, а не изменяем его, чтобы у нас был запасной вариант, если что-то пойдет не так (рис. 4)

```
(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ sudo cp config.inc.php.dist config.inc.php

(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ ls
config.inc.php config.inc.php.dist

(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$
```

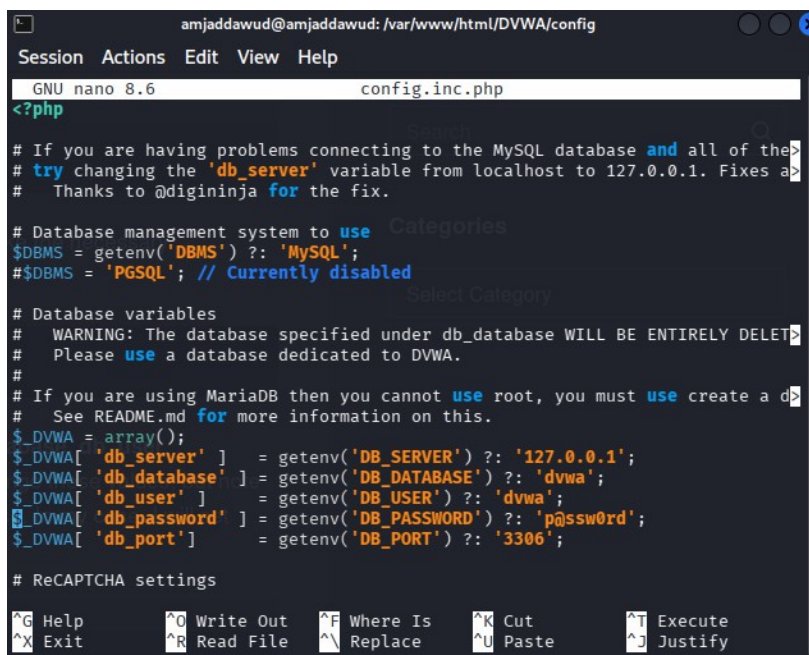
Рисунок 4.4: Создание копии файла

Далее открываю файл в текстовом редакторе (рис. 5)

```
(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ sudo nano config.inc.php
```

Рисунок 4.5: Открытие файла в редакторе

Изменяю данные об имени пользователя и пароле (рис. 6)



```
amjaddawud@amjaddawud: /var/www/html/DVWA/config
Session Actions Edit View Help
GNU nano 8.6 config.inc.php
<?php

# If you are having problems connecting to the MySQL database and all of the
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a
# Thanks to @diginiinja for the fix.

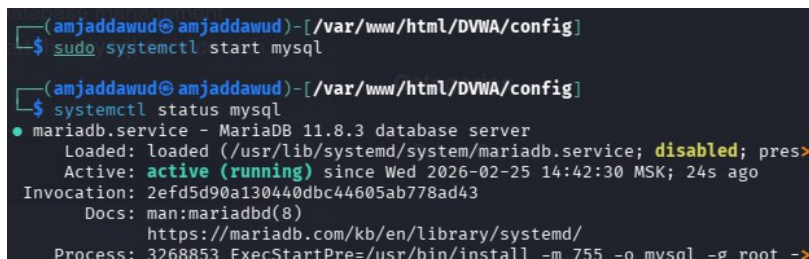
# Database management system to use
$DBMS = getenv('DBMS') ?: 'MySQL';
#$DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must create a database
# See README.md for more information on this.
$_DVWA = array();
$_DVWA['db_server'] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA['db_database'] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA['db_user'] = getenv('DB_USER') ?: 'dvwa';
$_DVWA['db_password'] = getenv('DB_PASSWORD') ?: 'p@ssw0rd';
$_DVWA['db_port'] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
```

Рисунок 4.6: Редактирование файл

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (рис. 7)



```
(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ sudo systemctl start mysql

(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ systemctl status mysql
● mariadb.service - MariaDB 11.8.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; pres>
   Active: active (running) since Wed 2026-02-25 14:42:30 MSK; 24s ago
   Invocation: 2efd5d90a130440dbc44605ab778ad43
   Docs: man:mariadb(8)
         https://mariadb.com/kb/en/library/systemd/
   Process: 3268853 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root ->
```

Рисунок 4.7: Запуск mysql

Авторизируюсь в базе данных от имени пользователя root. Появляется командная строка с приглашением «MariaDB», далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php (рис. 8)

```

(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.3-MariaDB-1+b1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement .

MariaDB [(none)]> create user 'userDVWA'@'127.0.0.1' identified by "dvwa";
Query OK, 0 rows affected (0.006 sec)

```

Рисунок 4.8: Авторизация в базе данных

Теперь нужно пользователю предоставить привилегии для работы с этой базой данных (рис. 9)

```

MariaDB [(none)]> grant all privileges on dvwa.* to 'userDVWA'@'127.0.0.1' identified by 'dvwa';
Query OK, 0 rows affected (0.003 sec)

MariaDB [(none)]> █

```

Рисунок 4.9: Изменение прав

Необходимо настроить сервер apache2, перехожу в соответствующую директорию (рис. 10)

```

(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ ls /etc/php
8.4

(amjaddawud@amjaddawud)-[/var/www/html/DVWA/config]
$ cd /etc/php/8.4/apache2

(amjaddawud@amjaddawud)-[/etc/php/8.4/apache2]
$ █

```

Рисунок 4.10: Перемещение между директориями

В файле `php.ini` нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе (рис. 11)

```

(amjaddawud@amjaddawud)-[/etc/php/8.4/apache2]
$ sudo nano php.ini █

```

Рисунок 4.11: Открытие файла в текстовом редакторе

В файле параметры `allow_url_fopen` и `allow_url_include` должны быть поставлены как `On` (рис. 12)

```
; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like https:// or ftp://) as
; https://php.net/allow-url-include
allow_url_include = On
```

Рисунок 4.12: Редактирование файла

Запускаем службу веб-сервера `apache` и проверяем, запущена ли служба (рис. 13)

```
(amjaddawud@amjaddawud)-[/etc/php/8.4/apache2]
$ sudo systemctl start apache2

(amjaddawud@amjaddawud)-[/etc/php/8.4/apache2]
$ systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; pres>
   Active: active (running) since Wed 2026-02-25 15:02:11 MSK; 15s ago
 Invocation: d26f336468c64604bab35ae6b52a76f8
    Docs: https://httpd.apache.org/docs/2.4/
  Process: 3278887 ExecStart=/usr/sbin/apachectl start (code=exited, statu>
 Main PID: 3278911 (apache2)
   Tasks: 6 (limit: 5335)
  Memory: 21.3M (peak: 21.3M)
    CPU: 819ms
   CGroup: /system.slice/apache2.service
           └─3278911 /usr/sbin/apache2 -k start
             └─3278914 /usr/sbin/apache2 -k start
               └─3278915 /usr/sbin/apache2 -k start
                 └─3278916 /usr/sbin/apache2 -k start
                   └─3278917 /usr/sbin/apache2 -k start
                     └─3278918 /usr/sbin/apache2 -k start
```

Рисунок 4.13: Запуск `apache`

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя `127.0.0.1/DVWA` (рис. 14)

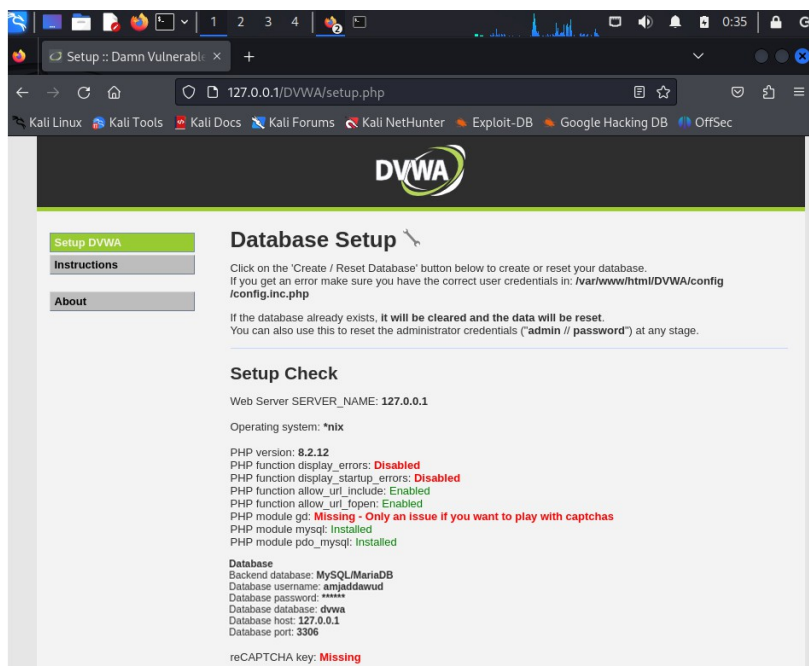


Рисунок 4.14: Запуск веб-приложения

Прокручиваем страницу вниз и нажимаем на кнопку `create\reset database` (рис. 15)

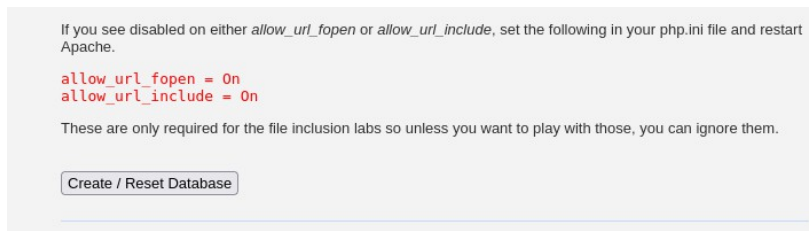


Рисунок 4.15: «Создание базы данных»

Авторизуюсь с помощью предложенных по умолчанию данных (рис. 16)



Username

Password

Login

Рисунок 4.16: Авторизация

Оказываюсь на домашней странице веб-приложения, на этом установка окончена (рис. 17)

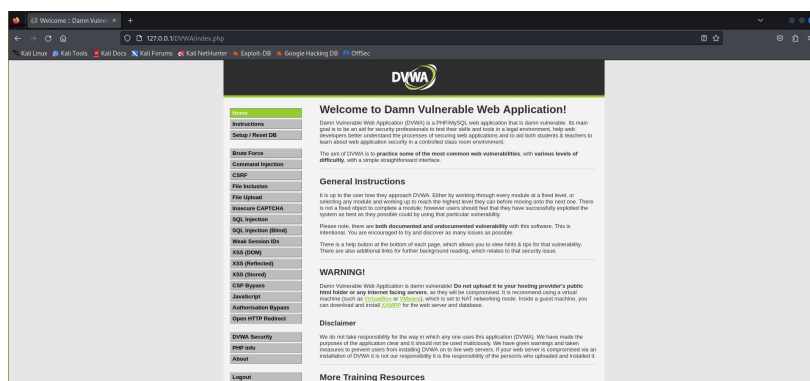


Рисунок 4.17: Домашняя страница DVWA

5 Выводы

Приобрела практические навыки по установке уязвимого веб-приложения DVWA.

Список литературы